Database Administration & Storage systems – IT4011

DATABASE SECURITY WITH ORACLE

Indika Alahapperuma

What is Database Security?

- Protects databases from unauthorized access and threats
- Ensures confidentiality, integrity, and availability (CIA)
- Safeguards sensitive business and customer data
- Required for compliance with data protection laws (GDPR, PDPA)

Common Threats to Databases

- Unauthorized internal and external access
- SQL Injection and application vulnerabilities
- Malware, ransomware attacks
- Data leakage and theft
- Backup and recovery failures

Core Principles of Database Security

- **Confidentiality:** Restrict access only to authorized users
- **Integrity:** Ensure data accuracy and prevent unauthorized alteration
- **Availability:** Keep data accessible when needed
- **Authentication:** Verify user identities
- **Authorization:** Control what users can access
- **Auditing:** Track database activities for analysis

Security Mechanisms Overview

- **User authentication:** passwords, MFA, centralized solutions
- **Access control:** roles, privileges, Virtual Private Database (VPD)
- **Encryption:** data-at-rest (TDE), data-in-transit (TLS)
- **Auditing and monitoring:** activity logging and alerting
- **Patch management:** updating software to fix vulnerabilities

Overview of Oracle Database Security

- Integrated, layered security architecture
- User, data, network, and application protection
- Support for enterprise compliance standards

Oracle User Authentication

- Password policies with complexity and expiration
- Account lockout after failed attempts
- Support for OS, LDAP, Kerberos authentication
- Multi-Factor Authentication for elevated security
- Single Sign-On (SSO) and centralized user management

Access Control in Oracle

- Privilege types: system vs object privileges
- Use of Roles to grant groups of privileges
- Enforce least privilege and separation of duties
- Virtual Private Database (VPD) for row-level security
- Oracle Label Security for classification-based access control

Oracle Virtual Private Database (VPD)

- Applies security policies by augmenting SQL queries dynamically
- Enables row-level security based on user attributes
- Useful in multi-tenant and regulated environments

Oracle Label Security

- **Each piece of data (row) is labelled with a security level**
  - Access is allowed based on the user's security level



Security Clearance = **Sensitive**

Application Table

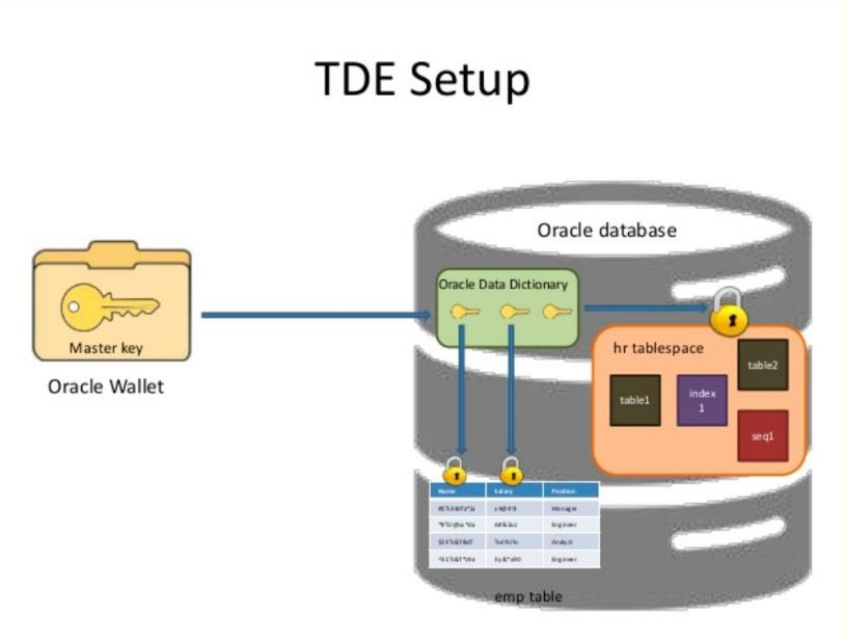
Store ID	Revenue	Department	Sensitivity Label
AX703	10200.34	Finance	Sensitive
B789C	18020.34	Engineering	Highly Sensitive
JFS845	15045.23	Legal	Confidential
SF78SD	21004.45	HR	Public

Data Encryption in Oracle

- Transparent Data Encryption (TDE) protects data-at-rest
- Encrypts tablespaces or selected columns
- Network encryption via Oracle Net Services
- Manual encryption using DBMS_CRYPTO package

Transparent Data Encryption

- Stops unauthorized attempts from the operating system to access database data stored in files
- Oracle Database encryption is the process of transforming data into an unreadable format using a secret key and an encryption algorithm.
- Transparent Data Encryption enables to encrypt individual table columns or a tablespace.
- When a user inserts data into an encrypted column, the database automatically encrypts the data.
- When users select the column, the data is decrypted.



Auditing and Monitoring with Oracle

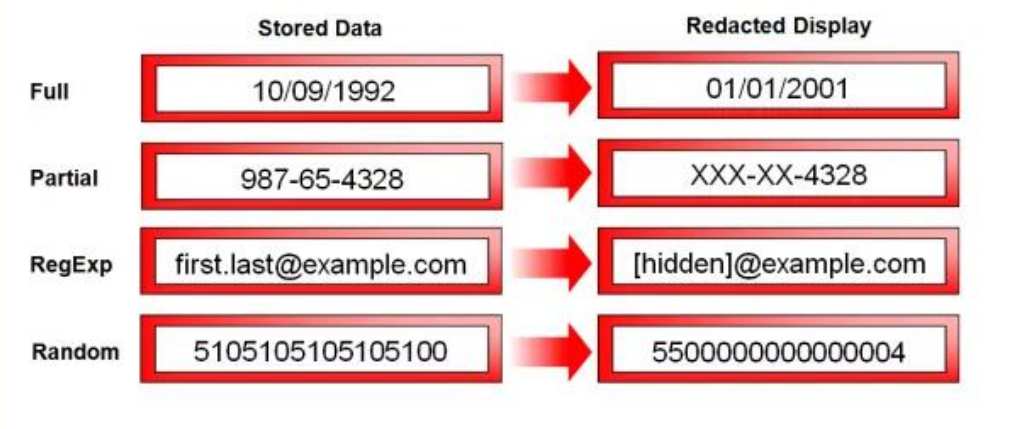
- Standard auditing tracks user activities
- Fine-Grained Auditing (FGA) enables detailed policy-based auditing
- Integration with Oracle Audit Vault and SIEM tools
- Critical for compliance, detecting breaches, and forensic analysis

Other Oracle Security Features

- Data Redaction and Masking to protect output data
- Database Firewall to block suspect transactions
- Regular security patching via Oracle Critical Patch Updates (CPU)

Data Redaction

- Is the process of hiding data prior to display by the applications
- Sensitive data is redacted on-the-fly without changing actual data stored in the database.



DBMS_REDACT

- Use DBMS_REDACT package to mask the data on-the-fly
- The Data Redaction policy applies to the querying user, depending on this user's SYS_CONTEXT values
- There are four data redaction function types
  - DBMS_REDACT.NONE
  - DBMS_REDACT.FULL
  - DBMS_REDACT.PARTIAL
  - DBMS_REDACT.RANDOM
- Reference
  - https://docs.oracle.com/database/121/ARPLS/d_redact.htm#ARPLS73807

DBMS_REDACT Examples

Create new table and redact Date data column

- CREATE USER app IDENTIFIED by redact123 DEFAULT TABLESPACE users;
- ALTER USER app quota unlimited ON users;
- GRANT CONNECT,RESOURCE TO app;
- GRANT EXECUTE ON dbms_redact TO app;
- CREATE TABLE emp(
  pk_emp_id INT GENERATED BY DEFAULT ON NULL AS IDENTITY,
  name VARCHAR2 (250),
  dob DATE,
  salary number
  );

DBMS_REDACT Examples Cont.

- Insert data

  INSERT INTO EMP (NAME, DOB, salary) VALUES ('SILVA', TO_DATE('1980-01-02', 'YYYY-MM-DD'), 35000);

- Add redaction policy - Redact to all users:

```
INSERT INTO EMP (NAME, DOB,salary) VALUES ('SILVA', TO_DATE('1980-01-02', 'YYYY-MM-DD'), 35000)

BEGIN
 DBMS_REDACT.ADD_POLICY (
   object_schema       => 'APP',
   object_name         => 'EMP',
   column_name         => 'DOB',
   policy_name         => 'REDACT_DATE_POLICY',
   function_type       => DBMS_REDACT.PARTIAL,
   function_parameters => 'MDy1',
expression             => '1=1'
 );
END;
/
```

DBMS_REDACT Examples Cont.

drop redaction policy

```
BEGIN
  DBMS_REDACT.drop_policy (
    object_schema => 'APP',
    object_name   => 'EMP',
    policy_name   => 'REDACT_DATE_POLICY'
  );
END;
/
```

DBMS_REDACT Examples Cont.

Add redaction policy – exclude some users/specific users:

```
BEGIN
 DBMS_REDACT.ADD_POLICY (
   object_schema       => 'APP',
   object_name         => 'EMP',
   column_name         => 'DOB',
   policy_name         => 'REDACT_DATE_POLICY',
   function_type       => DBMS_REDACT.PARTIAL,
   function_parameters => 'MDy1',
expression             => 'SYS_CONTEXT(''USERENV'', ''SESSION_USER'') != ''APP'''
 );
END;
/
```

Data Masking

- Data masking is a data security technique that replaces sensitive information with realistic but fictitious data.
- It conceals sensitive data in non-production environments such as development, testing, or training.
- Masked data retains the original format and structure, ensuring data usability while preventing exposure of real data.
- Commonly masks personally identifiable information (PII) like names, credit card numbers, or social security numbers.

Database Firewall

- An active, real-time firewall solution that monitors and protects databases at the SQL transaction level.
- Inspects all incoming SQL traffic to detect and block unauthorized or malicious queries like SQL injection.
- Supports white list (approved queries), black list (blocked queries), and exception list policies for fine-tuned control.

Oracle Security Patch Management

- Subscribe to Oracle Critical Patch Updates (CPU) alerts
- Test patches in a non-production environment first
- Schedule and apply patches regularly to production systems
- Implement rollback plans for emergency fixes
- Follow Oracle security advisories actively

Best Practices: Access Management

- Apply the principle of least privilege
- Regular privilege audits and revocation of unnecessary rights
- Use roles and profiles for manageable security
- Separate duties to prevent fraud and errors

Best Practices: Authentication Hardening

- Enforce strong password policies and rotation
- Use MFA wherever possible
- Centralize authentication (Active Directory, LDAP)
- Monitor authentication logs for suspicious activity

Best Practices: Data Encryption

- Enable Transparent Data Encryption (TDE) for sensitive data-at-rest
- Use TLS encryption for all network communications
- Apply column-level encryption for high-value or PII data
- Encrypt backups and archive data
- Manage and protect encryption keys securely

Best Practices: Network and Infrastructure Security

- Isolate database servers in secure network zones
- Apply firewall rules limiting access to Oracle service ports only
- Use VPNs or private network connections for remote database access
- Restrict database access only to trusted applications and services
- Employ network intrusion detection/prevention systems

Best Practices: System and Software Hardening

- Apply Oracle patches and Critical Patch Updates promptly
- Disable or remove default accounts and unused features
- Run Oracle services under least privileged OS accounts
- Perform vulnerability scans and harden the underlying OS environment
- Use configuration baselines and compliance checks

Best Practices: Monitoring and Auditing

- Enable auditing for user activities and sensitive transactions
- Use Oracle Audit Vault or equivalent to centralize audit logs
- Regularly review audit logs and set up alerting on suspicious activities
- Integrate DB audit logs with enterprise SIEM systems
- Conduct periodic security audits and penetration tests

Best Practices: Backup and Disaster Recovery

- Perform regular full and incremental backups with encryption
- Store backups securely offsite and test restore procedures frequently
- Follow data retention and compliance policies for backup data
- Use Oracle RMAN tool for efficient backup and recovery
- Document and rehearse disaster recovery plans

Security Awareness and Training

- Train DBAs and developers on secure database design and coding
- Promote awareness of SQL injection, privilege escalation, and social engineering
- Develop and enforce database security policies across the enterprise
- Encourage regular security training and updates based on emerging threats

Recent Major Database Security Breaches

- **Allianz Life Insurance Breach**
  Exposure of personal info of 1.4 million US customers via third-party cloud CRM hack.
  Impacted customer privacy, led to remediation and notifications.
- **Oracle Cloud Credentials Breach**
  6 million Oracle Cloud records including key files and encrypted passwords leaked from SSO and LDAP systems.
  Affected 140,000+ Oracle tenants; risk of unauthorized cloud access.
- **Genea Fertility Clinic Ransomware**
  940GB patient data exfiltrated including medical histories and contact info.
  Raised healthcare cybersecurity concerns.
- **16 Billion Passwords Leak**
  Infostealer malware exposed credentials across multiple major platforms.
  Heightened risk of account takeover.

Lesson Learned from Most of the Database Security Breaches

- Importance of multi-layered database security controls
- Vigilance for third-party and cloud platform security
- Strong authentication and encryption essential
- Rapid incident response and transparency
- Regular training and security audits